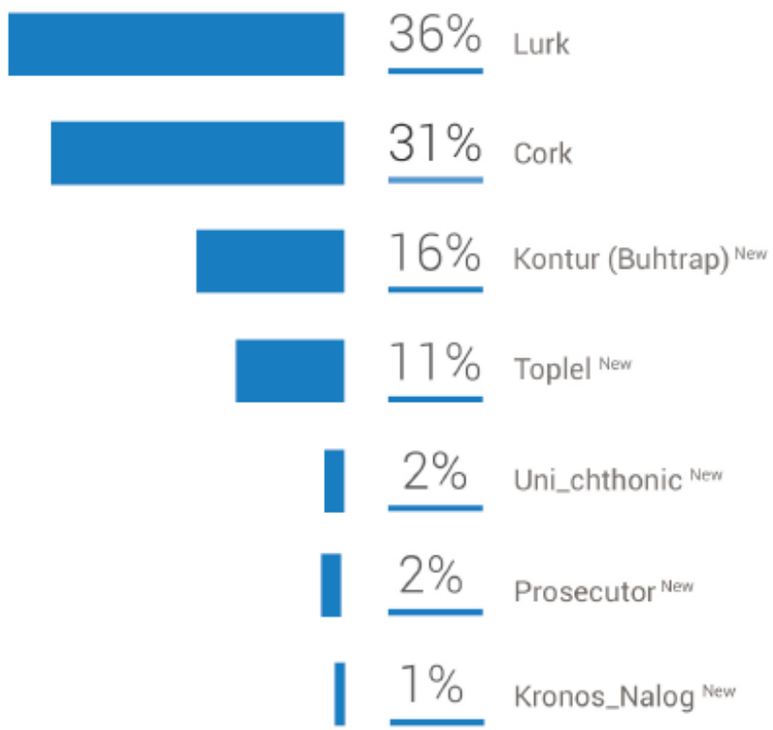
LURK

GANG PROFILE

July 2016



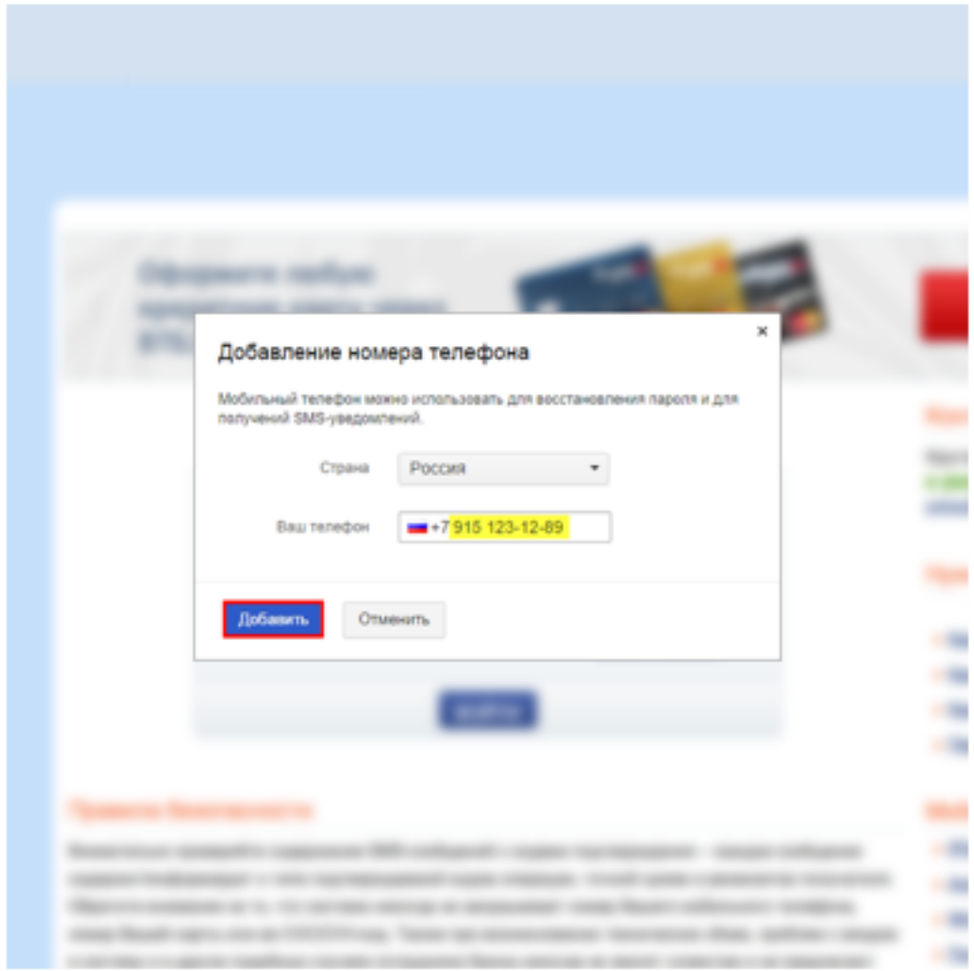
Thefts from corporate bank accounts, Russia and the CIS, QIII 2014 - QII 2015

Group-IB Report "The Hi-Tech Crime Trends 2015"

On June 1, 2016 law enforcement officials announced the arrest of 50 members of the Lurk gang, which had been **the most dangerous threat to companies in Russia and the CIS** for a long period. In 2014 approximately 36% of theft from corporate accounts were committed by the Lurk gang.

According to expert evaluations, over a 5-year period the group **stole more than 3 billion rubles ($50 mln USD)** in total.

Since 2010 the gang had been developing their customized Trojan and were infecting popular business portals and thematic resources for accountants and financial experts in order to distribute malware.



Example of an attack using the Lurk web inject – a malicious injection into the user's browser, which enables criminals to make necessary changes to the online banking pages being displayed in order to collect additional information on the victim (for example, a phone number)

Lurk developers focused on creating a tool for more **automated fraudulent transactions** with the function to bypass SMS authentication.

The Trojan combined the functionality of different fraud and cyber espionage Trojans, which enabled criminals

- **to manipulate online banking pages** being displayed and secretly replace banking credentials and payment amounts;
- **to bypass payment verification** via token and SMS;
- **to collect users' data** (including passwords from iCloud and Gmail) and capture their online activity;
- **to conceal its presence** from the victim using various tricks, including blockage of client complaints to the bank.

2011-2014
ATTACKS ON CORPORATE BANK ACCOUNTS

837

banks and branches

650 000

corporate clients

450 000

private clients

ibank by Bifit client base

Bifit, 2012

The Trojan was initially developed to attack Ibank, a popular Russian online banking system designed by Bifit.

Ibank2 is a Java applet, which was modified by Lurk each time it was launched, enabling the criminals to **intercept and manipulate data exchanged between infected computer and online banking system.**

These manipulations allowed the cybercriminals to **furtively replace data in payment orders** with those received from the Lurk C&C server just before the signing of such orders by victims.

LURK FEATURES

AUTOMATED DATA REPLACEMENT

The victim saw original information (beneficiary credentials, amount of payment, etc.) on the screen and approved fraudulent money transfer without any suspicious.

The Lurk malware replaced displayed data directly in online banking, so even the bank statement showed the original payment details.

```
g.each(c, function(c, e) {
    var p = c["Сумма"],
        q = c["ПлательщикРасчСчет"];
    if (p && q)
        if (c["ПоказательКБК"] || c["ОКАТО"]) n.warn("налоговый платеж, отменяем перехват."), a.push(p);
        else {
```

“tax payment, cancel interception.”

It’s worth noting that when a victim paid taxes, the malicious program did not execute automated data replacement orders.

LURK FEATURES

AUTOFILL ("AVTOZALIV")

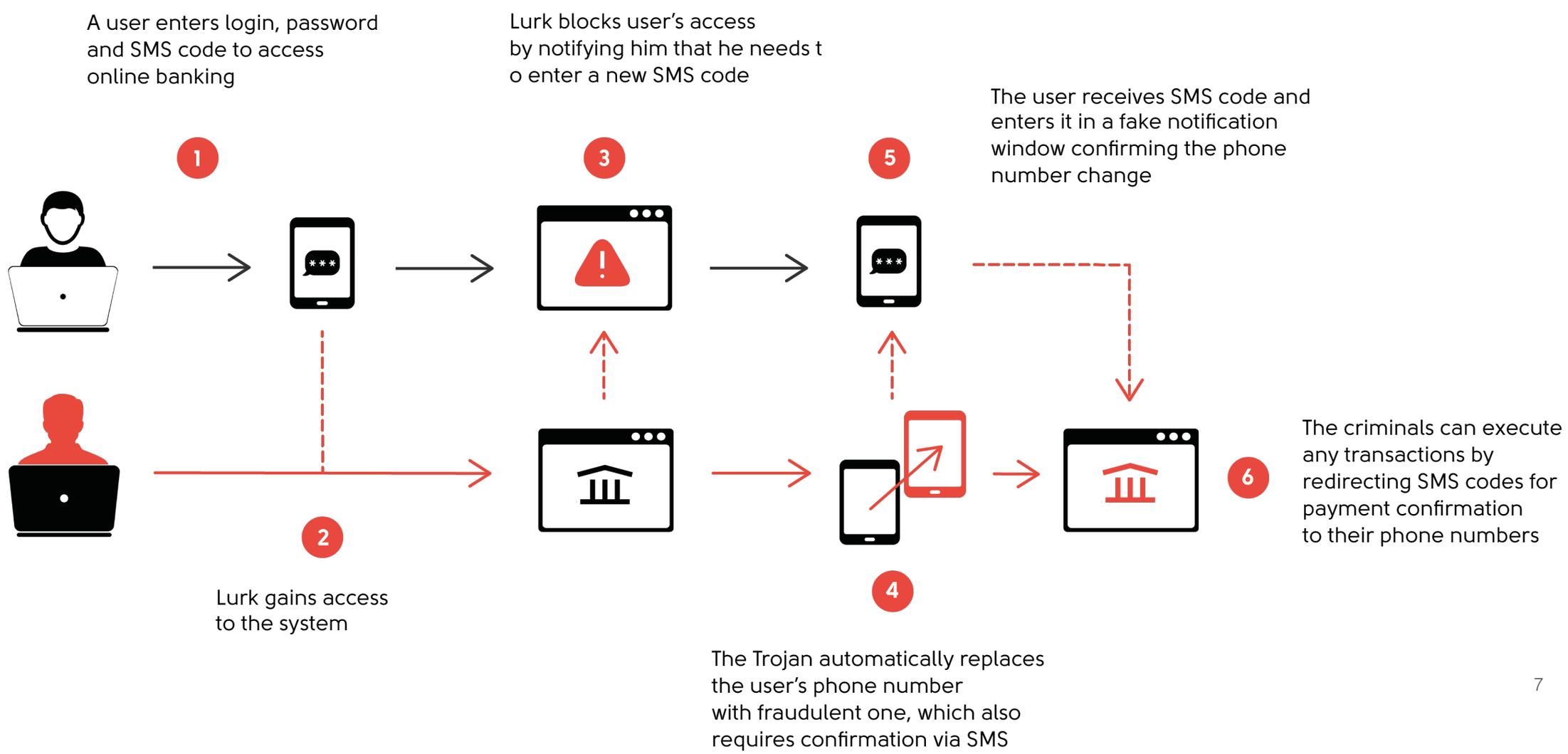
Later hackers complemented the Trojan with the function to **create, sign and send payment orders to the bank without victim participation.**

Banks were not able to detect such fraudulent activity unless they had specialized security tools, because all payments were executed from the user's computer at unsuspicious times and were signed with a real digital signature.

LURK FEATURES

BYPASSING SMS AUTHENTICATION

An additional challenge for criminals was to automate fraudulent transactions for those clients who used SMS code authentication to confirm payments.
To **substitute phone numbers used for SMS authentication** the Lurk group developed the following scheme:



LURK FEATURES

BYPASSING SMS AUTHENTICATION

Some banks do not ask for additional SMS confirmation for online transactions, if the recipient of the funds is added to a list of trusted parties. However, they require SMS confirmation to add a beneficiary to the list.

The criminals added their own recipients to "favourites" using the same scheme as in phone number substitution, so they can arrange fraudulent transactions without any additional confirmation.

LURK FEATURES

ADVANCED STEALTHY TECHNIQUES

The Trojan used various tricks to remain undetected by anti-virus tools and endpoint security solutions. The criminals are known to have hidden traces of their activity using VPN, Tor, and compromised Wi-Fi networks as well as servers of attacked companies.

The group acted cautiously: for example, by only installing the core module of the Trojan on computers of their specific interest. In other cases the Trojan launcher removed itself from the system.

Lurk lost a chance to create the largest botnet in the CIS, however such cautiousness enabled them to keep their activity “under the radar”.

Also, **Lurk monitored for user attempts to inform the bank of fraudulent transactions,** searching for such key words as “recall”, “cancel”, “delete” in messages sent to the bank’s address.

```
var b = f(["отзыв", "отмен", "отозвать", "удал"]);
a.ondefine("before_send", function() {
    a.inject.after({
        target: x,
        method: "before_send"
    }, function(e) {
        var d = n.doc.chain().where({
                status: /^(NEW|SIG|PRC|PBE)$/
            }),
            c = $("#To").val(),
            g = $("#From").val(),
            h = $("#Body").val(),
            q = $("#Subject").val(),
            m = document.createElement("div");
        m.innerHTML = h;
        var p =
            a.Sizzle.getText([m]);
        l.debug(["данные письма: адрес[%s] тема(%s), содержимое: %s", c, q, h]);
        if (!1 === e) return e;
        if (!d.size().value()) return z.log("Нет документов которые можно было бы отозвать"),
            e;
        d = d.filter(function(b) {
            var c = RegExp("(^|\\s)" + b.number + "|" + b.recipient_account + "|" + b.recipie
                d = !!f([p, q]).filter(function(a) {
                    return c.test(a.replace(/[^0-9]+/g, " "))
                }).length;
            d && (n.doc.update({
                id: b.id,
                type: "COMMAND"
            }, {
                withdrawn: !0
            }), l.error(["Документ #%s(№%s) обнаружен холдером", b.id, b.number]));
            return d
```

“<fraudulent> document detected by <account> holder”

Once detected, Lurk blocked such messages and **sent criminals notifications** of its detection by the victim.

INDUSTRIAL ESPIONAGE

The Trojan was allegedly used for industrial espionage: it monitored the activity of windows, which titles contained the following words: “UMMC” (Ural Mining and Metallurgical Company, one of the largest metallurgical companies in Russia), “copper”, “marble”, or “granite”.

Keylogger sent collected information to the C&C server. Triggers included titles of windows and executive files related to the financial sector, including banks, payment systems, and POS terminals.

The criminals also looked for **computers interacting with government systems** including those collecting fingerprints, e-government infrastructure*, as well as with Group-IB’s Bot-Trek systems.

* – Automated Fingerprint Identification System (AFIS), Government Services Registration System, System of Interdepartmental Requests

TARGETED DISTRIBUTION

While developing the Trojan functionality, the group **infected websites popular among users from Lurk's "target audience"**, such as news aggregators, business media, thematic resources for accountants and financial experts and major online classifieds in order to distribute exploits.

Websites visitors didn't notice anything suspicious as they were stealthily redirected to a server with Angler exploit kit, also known as XXX (more details on Angler see p.21), which scanned computers for vulnerabilities. In case of success the Lurk malware was installed on vulnerable computers.

For example, over several years Lurk had access to one of the most popular banking portals bankir.ru.

They acted very carefully, running scripts initiating infections on visitors only for short periods and not every day, so that they were not detected by the website owners.

2014-2015
IN SEARCH OF NEW VICTIMS

Cork
Lurk
~~Shiz~~
~~Ranbyus~~
~~Infinity~~
Toplel[New]
Kontur (Buhtrap)[New]
Uni_chthonic[New]
Prosecutor[New]
Kronos_Nalog[New]
Yebot[New]

Groups targeting Russian and CIS companies, QIII 2014 - QII 2015

Group-IB Report "The Hi-Tech Crime Trends 2015"

While the Lurk group were modifying the Trojan for ibank, **new hacker gangs appeared**, which attacked various online banking systems and ready-to-use automated transfer systems also became available for purchase.

The above-mentioned situation along with anti-money laundering campaigns and **the drastic devaluation of the ruble in the second half of 2015** made hackers increase their activity – they needed to double the number of thefts to get their usual profit in foreign currency.

To increase the frequency and average scale of attacks criminals had to search for new victims.

IN SEARCH OF NEW VICTIMS

OTHER ONLINE BANKING SYSTEMS

Since early 2015 Lurk had **started attacking clients of different online banking systems** using new modules with web injects designed to perform man-in-the-browser attacks to perform "autofill" and collect additional information.

When an infected user visited its internet banking page, **web injects collected data on the account**, balance, transactions **and made necessary changes to the pages** being displayed in order to replace data.

In some cases, web injects were used to display additional fields on online banking pages in order to **obtain client's mobile phone number.**

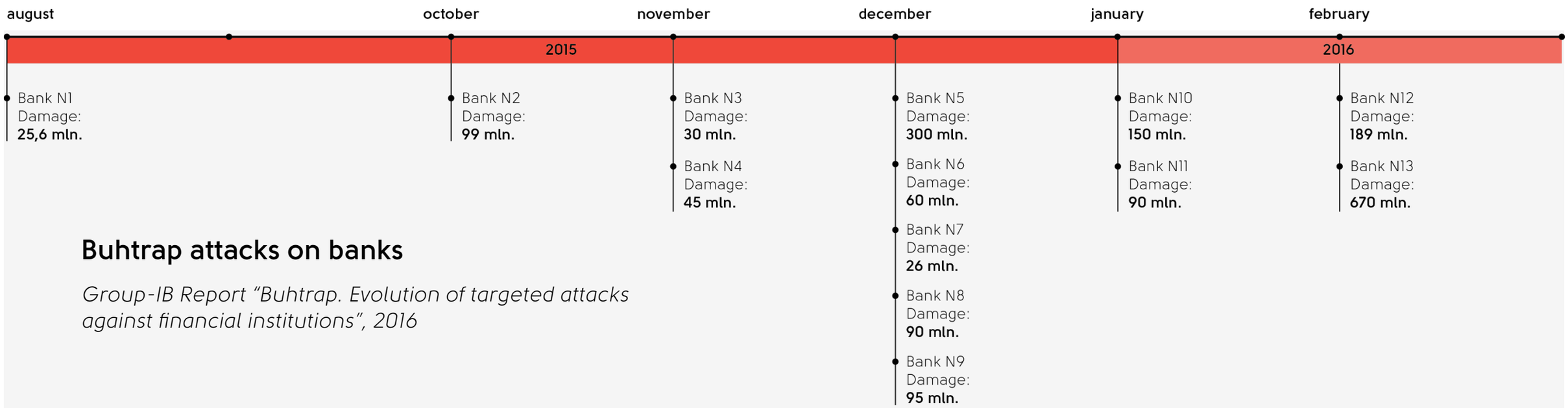
IN SEARCH OF NEW VICTIMS

TRADING PLATFORMS

Just like the Corkow group, Lurk created a module for collecting data from the Quik trading software developed by ARQA technologies. However, unlike Corkow, Lurk was unable to utilize the module.

IN SEARCH OF NEW VICTIMS

BANKS



Buhtrap attacks on banks

Group-IB Report "Buhtrap. Evolution of targeted attacks against financial institutions", 2016

The end of 2015 saw an unprecedented wave of successful attacks on Russian banks. From October to December 2015 the Buhtrap group managed to steal more than 700 mln rubles ($11 mln) from 8 banks (for more details of this campaign see our report on Buhtrap).

Before the campaign Buhtrap had targeted corporate bank accounts and had lagged significantly behind "the market leader" with the third position among hacker groups in terms of the amount of fraud in this segment.

The Lurk group also decided to shift to a new market.

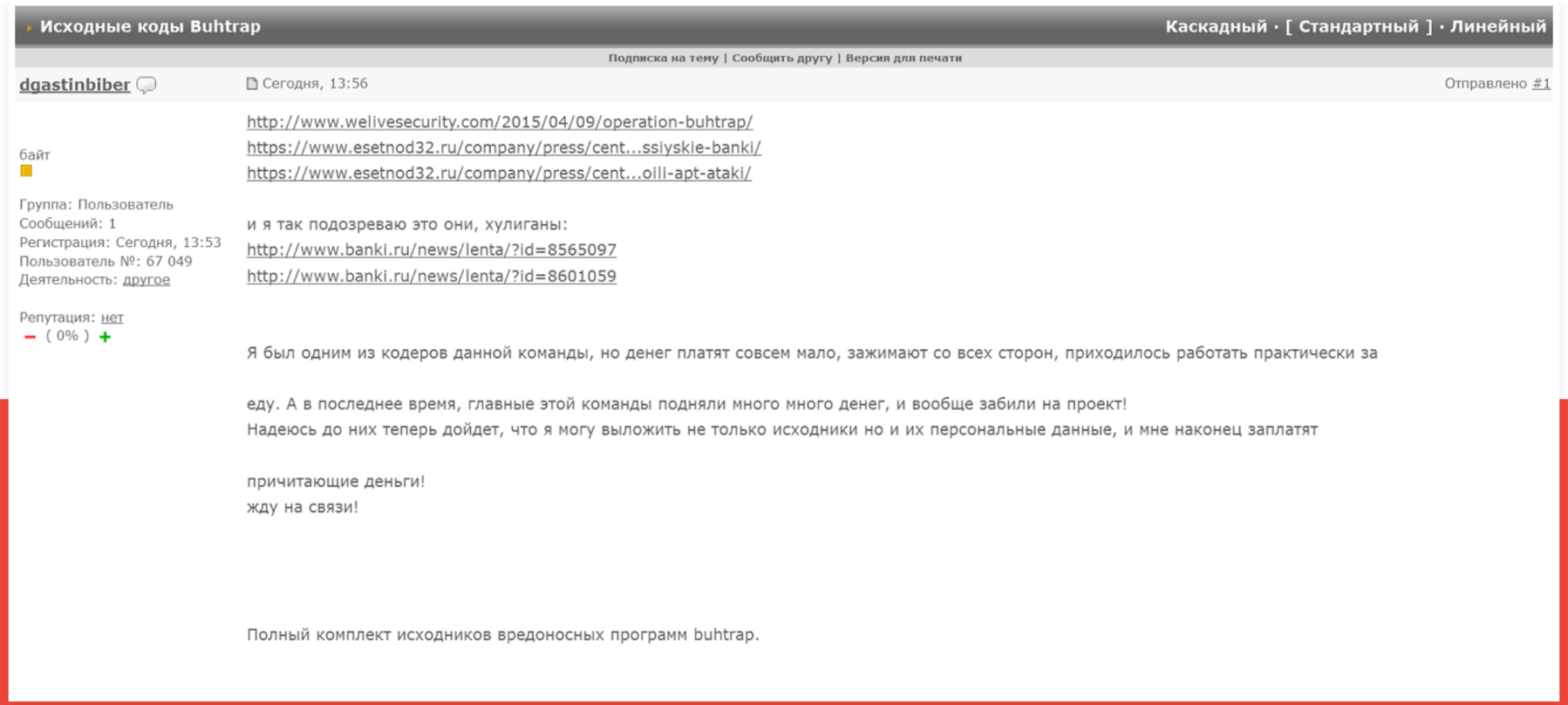
2016
ATTACKS ON BANKS

On February 3, 2016 we notified Group-IB Bot-Trek™ Intelligence subscribers that **the group had changed the Trojan in order to conduct targeted attacks on banks**, which protected them from attacks that started in mid-February.

Just like the Buhtrap Trojan, the updated Lurk Trojan scanned systems for the AWS CBC (Automated Working Station of the Central Bank Client) application and it also contained a built-in Mimikatz module (a tool designed to gather domain account credentials) and the HVNC module for remote control over an infected machine.

AWS CBC is a software that allows banks to arrange funds transfers to other banks and financial institutions.

AWS CBC is freely available on The Bank of Russia official website, anyone can download it and test its functions.



Исходные коды Buhtrap

Каскадный · [Стандартный] · Линейный

Подписка на тему | Сообщить другу | Версия для печати

dgastinbiber

Сегодня, 13:56

Отправлено #1

байт

Группа: Пользователь
Сообщений: 1
Регистрация: Сегодня, 13:53
Пользователь №: 67 049
Деятельность: другое

Репутация: нет
(0%)

http://www.welivesecurity.com/2015/04/09/operation-buhtrap/
https://www.esetnod32.ru/company/press/cent...ssiyskie-banki/
https://www.esetnod32.ru/company/press/cent...oili-apt-ataki/

и я так подозреваю это они, хулиганы:
http://www.banki.ru/news/lenta/?id=8565097
http://www.banki.ru/news/lenta/?id=8601059

Я был одним из кодеров данной команды, но денег платят совсем мало, зажимают со всех сторон, приходилось работать практически за

еду. А в последнее время, главные этой команды подняли много много денег, и вообще забили на проект!
Надеюсь до них теперь дойдет, что я могу выложить не только исходники но и их персональные данные, и мне наконец заплатят

причитающие деньги!
жду на связи!

Полный комплект исходников вредоносных программ buhtrap.

Screenshot of the message with the Buhtrap source code

On February 5, 2016 a message with a link to the Buhtrap source code was published on an underground cybercrime forum by one of its authors, since he allegedly hadn’t been paid for developing the project.

ATTACKS ON BANKS

FIRST VICTIMS

February 2016

Russian bank
$2,300,000

March 2016

Ukranian bank
(an attempt was blocked)

Russian bank
$6,200,000
(a part of stolen money was returned)

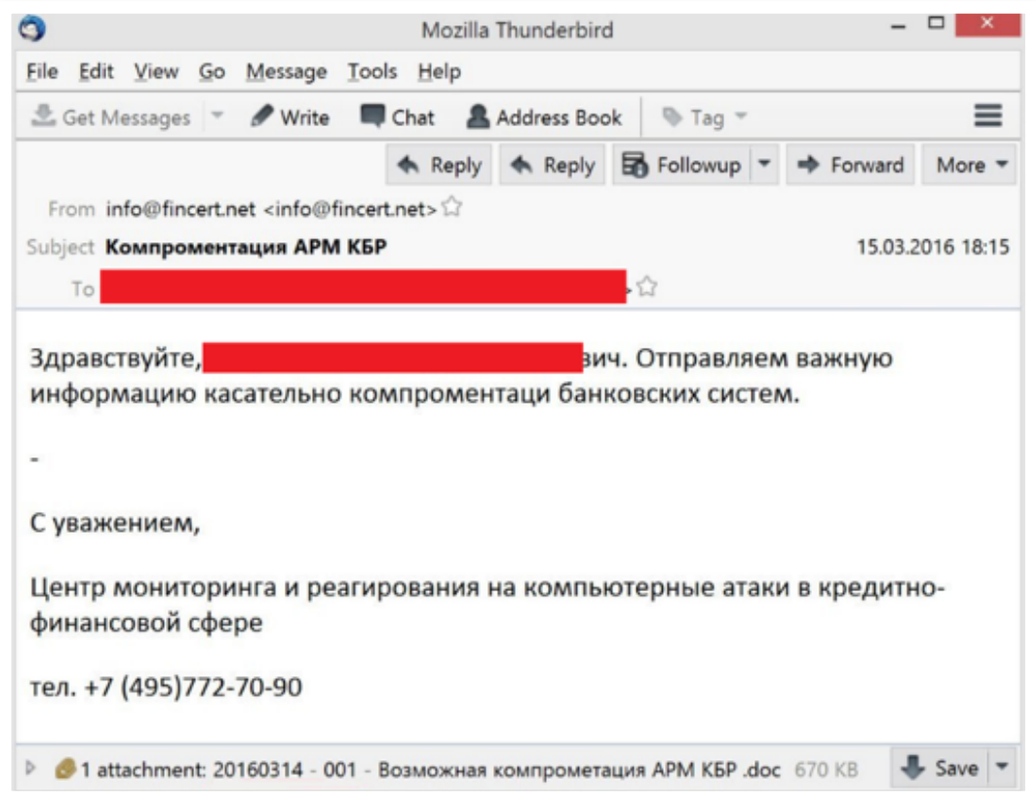
The first attack resulted in theft of 150 mln. rubles ($2.3 mln) and was then followed by unsuccessful attempts involving Ukrainian bank.

In March 2016 the group stole over 400 mln. rubles ($6.2 mln) from a Russian bank, however, due to the prompt reaction of law enforcement and the bank's security service the majority of money was returned.

After infecting the bank's network Lurk acted 100% identically to the tactics used by the Buhtrap group (for details see our report on Buhtrap).

ATTACKS ON BANKS

SPEAR PHISHING ATTACK



Lurk phishing email purporting to be from FinCERT

The Lurk gang not only appropriated the Buhtrap source code, but also used its “trademark” infection vector – **spear phishing emails** – in further attacks.

On March 15, 2015 **hundreds of bank security specialists received emails purporting to be from FinCERT** (incident response centre of the Bank of Russia).

The letters contained malicious attachments with the same VBA macro, which execution led to launching a dropper designed based on the leaked Buhtrap source code.

The dropper then installed LiteManager, a tool for remote control, which had been used by Buhtrap, however, the Lurk Trojan was installed on victims’ computers instead of the Buhtrap malware.

The first phishing attack conducted by Lurk was also the last: in May the group’s leaders were arrested in Ekaterinburg, while other members were caught across the country.

AFTER LURK'S ARREST

The Lurk group had wide connections in the hacker community and its arrest has influenced the amount of crimes both in Russia and abroad.

Just after the arrest, cybercrime groups stopped using the most popular exploit kit "Angler", which had purportedly been developed with the participation of Lurk members. The following facts confirm the involvement of those arrested:

- Development of the Lurk malware and the Angler exploit kits started at roughly the same time – in 2010.
- Angler is a very popular exploit pack and has been actively used to spread various malware outside Russia. However, in Russia Angler has been used to distribute only one Trojan – Lurk.
- The same domain name registrar DomainContext had been used to register domains for both Lurk and Angler for many years.

AFTER LURK'S ARREST

It will cost over $200,000 to create a Trojan similar to Lurk, that's why owners of its source code fragments can expect profitable offers from other criminal groups. **Source code leakage may strengthen positions of active market players and attract new participants.**

We expect new and existing participants using banking Trojans to leverage technology designed to automate e-banking manipulation and bypass SMS dual factor authentication. Additionally, **the Trojan's cyber espionage tools and stealthy evasion techniques help to avoid detection and are likely to encourage the interest of cyber terrorists and government cyber armies.**

Group-IB is one of the most innovative companies dedicated to preventing and investigating high-tech crimes and online fraud.

Since 2003, the company has been active in the field of computer forensics and information security, protecting the largest international companies against financial losses and reputational risks.

Learn more on Group-IB.com

Official Europol partner

Recommended by the Organization for Security and Co-operation in Europe (OSCE)

Threat intelligence vendor recognized by Gartner

Bot-Trek – Early Warning System For Proactive Cyber Defence

Bot-Trek Intelligence

Real-time personalized threat intelligence: detection, analysis and forecasts of threats targeting your business

Bot-Trek TDS

Intelligence-driven threat detection for corporate networks

Bot-Trek Secure Bank

Early warning system for online fraud prevention for banks and payment system

Bot-Trek Intelligence subscribers were made aware of Lurk Trojan updates and provided with indicators of compromise, keylogger triggers and other data vital in preventing Lurk attacks

Unlike AVs and endpoint security products, Bot-Trek TDS immediately detected Lurk activity in our clients' networks

Bot-Trek Secure Bank enabled banks to prevent thefts by blocking access to the online banking for users infected with Lurk Trojan